How to Contact the Publisher

If you believe you've found a mistake in this book, please bring it to our attention. At John Wiley & Sons, we understand how important it is to provide our customers with accurate content, but even with our best efforts an error may occur.

In order to submit your possible errata, please email it to our Customer Service Team at wileysupport@wiley.com with the subject line “Possible Book Errata Submission.”

Assessment Test

1. Which header field is used to reassemble fragmented IP packets?

    A. Destination address

    B. IP identification

    C. Don't fragment bit

    D. ToS field

2. If you were to see the following in a packet capture, what would you expect was happening?

    ```
    ' or 1=1;
    ```

    A. Cross-site scripting

    B. Command injection

    C. SQL injection

    D. XML external entity injection

3. What method might you use to successfully get malware onto a mobile device?

    A. Through the Apple Store or Google Play Store

    B. External storage on an Android

    C. Third-party app store

D. Jailbreaking

4. What protocol is used to take a destination IP address and get a packet to a destination on the local network?

   A. DHCP

   B. ARP

   C. DNS

   D. RARP

5. What would be the result of sending the string AAAAAAAAAAAAAAAA into a variable that has been allocated space for 8 bytes?

   A. Heap spraying

   B. SQL injection

   C. Buffer overflow

   D. Slowloris attack

6. If you were to see the subnet mask 255.255.248.0, what CIDR notation (prefix) would you use to indicate the same thing?

   A. /23

   B. /22

   C. /21

   D. /20

7. What is the primary difference between a worm and a virus?

   A. A worm uses polymorphic code.

   B. A virus uses polymorphic code.

   C. A worm can self-propagate.

   D. A virus can self-propagate.

8. How would you calculate risk?

   A. Probability * loss

B. Probability * mitigation factor

C. (Loss + mitigation factor) * (loss/probability)

D. Loss * mitigation factor

9. How does an evil twin attack work?

   A. Phishing users for credentials

   B. Spoofing an SSID

   C. Changing an SSID

   D. Injecting four-way handshakes

10. To remove malware in the network before it gets to the endpoint, you would use which of the following?

    A. Antivirus

    B. Application layer gateway

    C. Unified threat management appliance

    D. Stateful firewall

11. What is the purpose of a security policy?

    A. Providing high-level guidance on the role of security

    B. Providing specific direction to security workers

    C. Increasing the bottom line of a company

    D. Aligning standards and practices

12. What has been done to the following string?

```
%3Cscript%3Ealert('wubble');%3C/script%3E
```

    A. Base64 encoding

    B. URL encoding

    C. Encryption

    D. Cryptographic hashing

13. What would you get from running the command `dig ns domain.com`?

A. Mail exchanger records for `domain.com`

B. Name server records for `domain.com`

C. Caching name server for `domain.com`

D. IP address for the hostname `ns`

14. What technique would you ideally use to get all of the hostnames associated with a domain?

A. DNS query

B. Zone copy

C. Zone transfer

D. Recursive request

15. If you were to notice operating system commands inside a DNS request while looking at a packet capture, what might you be looking at?

A. Tunneling attack

B. DNS amplification

C. DNS recursion

D. XML entity injection

16. What would be the purpose of running a ping sweep?

A. You want to identify responsive hosts without a port scan.

B. You want to use something that is light on network traffic.

C. You want to use a protocol that may be allowed through the firewall.

D. All of the above.

17. How many functions are specified by NIST's cybersecurity framework?

A. 0

B. 3

C. 5

D. 4

18. What would be one reason not to write malware in Python?

    A. The Python interpreter is slow.

    B. The Python interpreter may not be available.

    C. There is inadequate library support.

    D. Python is a hard language to learn.

19. If you saw the following command line, what would you be capturing?

```
tcpdump -i eth2 host 192.168.10.5
```

    A. Traffic just from 192.168.10.5

    B. Traffic to and from 192.168.10.5

    C. Traffic just to 192.168.10.5

    D. All traffic other than from 192.168.10.5

20. What is Diffie-Hellman used for?

    A. Key management

    B. Key isolation

    C. Key exchange

    D. Key revocation

21. Which social engineering principle may allow a phony call from the help desk to be effective?

    A. Social proof

    B. Imitation

    C. Scarcity

    D. Authority

22. How do you authenticate with SNMPv1?

    A. Username/password

    B. Hash

C. Public string

D. Community string

23. What is the process Java programs identify themselves to if they are sharing procedures over the network?

A. RMI registry

B. RMI mapper

C. RMI database

D. RMI process

24. What do we call an ARP response without a corresponding ARP request?

A. Is-at response

B. Who-has ARP

C. Gratuitous ARP

D. IP response

25. What are the three times that are typically stored as part of file metadata?

A. Moves, adds, changes

B. Modified, accessed, deleted

C. Moved, accessed, changed

D. Modified, accessed, created

26. Which of these is a reason to use an exploit against a local vulnerability?

A. Pivoting

B. Log manipulation

C. Privilege escalation

D. Password collection

27. What principle is used to demonstrate that a signed message came from the owner of the key that signed it?

A. Nonrepudiation

B. Nonverifiability

C. Integrity

D. Authority

28. What is a viable approach to protecting against tailgating?

A. Biometrics

B. Badge access

C. Phone verification

D. Man traps

29. Why is bluesnarfing potentially more dangerous than bluejacking?

A. Bluejacking sends, while bluesnarfing receives.

B. Bluejacking receives, while bluesnarfing sends.

C. Bluejacking installs keyloggers.

D. Bluesnarfing installs keyloggers.

30. Which of the security triad properties does the Biba security model relate to?

A. Confidentiality

B. Integrity

C. Availability

D. All of them

Answers to Assessment Test

1. B. The destination address is used as the address to send messages to. The don't fragment bit is used to tell network devices not to fragment the packet. The Type of Service (ToS) field can be used to perform quality of service. The IP identification field is used to identify fragments of the same packet, as they would all have the same IP identification number.

2. C. A SQL injection attack makes use of SQL queries, which can include logic that may alter the flow of the application. In the example provided, the intent is to force the result of the SQL query to always return a true. It is quoted the way it is to escape the existing query already in place in the application. None of the other attacks uses a syntax that looks like the example.
3. C. The Apple App Store and the Google Play Store are controlled by Apple and Google. It's not impossible to get malware onto mobile devices that way, but it's very difficult because apps get run through a vetting process. While some Android devices will support external storage, it's not an effective way to get malware onto a smartphone or other mobile device. Jailbreaking can lead to malware being installed, but it's not the means to get malware onto a mobile device. Third-party app stores can be a good means to get malware onto mobile devices because some third-party app stores don't vet apps that are submitted.
4. B. DHCP is used to get IP configuration to endpoints. DNS is used to resolve a hostname to an IP address and vice versa. RARP is the reverse address protocol used to take a MAC address and resolve it to an IP address. ARP is used to resolve an IP address to a MAC address. Communication on a local network requires the use of a MAC address. The IP address is used to get to systems off the local network.
5. C. Heap spraying uses dynamically allocated space to store attack code. A slowloris attack is used to hold open web server connection buffers. A SQL injection will be used to inject SQL queries to the database server. A buffer overflow sends more data into the application than space has been allocated for.
6. B. A /23 network would be 255.255.254.0. A /22 would be 255.255.252. A /20 would be 255.255.240.0. Only a /21 would give you a 255.255.248.0 subnet mask.
7. C. Both worms and viruses could be written to use polymorphic code, which means they could modify what they look like as they propagate. A worm, though, could self-propagate. It's the one distinction between worms and viruses. Viruses require some intervention on the part of the user to propagate and execute.

8. A. Risk is the probability of the occurrence of an event multiplied by the dollar value of loss. There is no mitigation factor that is quantified, so it couldn’t be used for a risk calculation.
9. B. An evil twin attack uses an access point masquerading to be the point of connection for stations trying to connect to a legitimate wireless network. Stations reach out to make connections to this access point masquerading as another access point. While you may phish for credentials as part of an evil twin attack, credential phishing is not how evil twin attacks work. SSIDs don't get changed as part of an evil twin attack, meaning no SSID that exists will become another SSID. Injecting four-way handshakes won't do much, since four-way assumes both ends are communicating, so the injection of a full communication stream will get ignored.
10. C. Antivirus solutions are used on endpoints or maybe on email servers. Stateful firewalls add the ability to factor in the state of the connection—new, related, established. An Application layer gateway knows about Application layer protocols. A unified threat management appliance adds capabilities on top of firewall functions, including antivirus.
11. A. Standards and practices should be derived from a security policy, which is the high-level guidance on the role of security within an organization. Security does not generally increase the bottom line of a company. Policies are not for providing specific directions, which would be the role of procedures.
12. B. Base64 encoding takes nonprintable characters and encodes them in a way that they can be rendered in text. Encryption would generally render text unreadable to people. A cryptographic hash is a way of generating a fixed-length value to identify a value. URL encoding takes text and uses hexadecimal values to represent the characters. This is text that has been converted into hexadecimal so it can be used in a URL.
13. B. Mail exchanger records would be identified as MX records. A name server record is identified with the tag `ns`. While an enterprise may have one or even several caching name servers, the caching name

server wouldn't be said to belong to the domain since it doesn't have any domain identification associated with it.

14. C. A DNS query can be used to identify an IP address from a hostname, or vice versa. You could potentially use a brute-force technique to identify hostnames, though you may not get everything using that method. A recursive request is common from a caching server to get an authoritative response. The term for getting all the contents of the zone is a zone transfer.
15. A. Tunneling attacks can be used to hide one protocol inside another. This may be used to send operating system commands using a tunnel system. A DNS amplification attack is where a small DNS request results in much larger responses sent to the target. DNS recursion is used to look up information from DNS servers. An XML entity injection attack is a web-based attack and wouldn't be found inside a DNS request.
16. D. There may be several reasons for performing a ping sweep. You likely want to identify responsive hosts on the network segment you are targeting. You may not, though, want to use a full port scan. ICMP is a lightweight protocol, and there is a chance it will be allowed through the firewall, since it's used for troubleshooting and diagnostics.
17. C. The NIST cybersecurity framework specifies five functions—identify, protect, detect, respond, recover.
18. B. Python interpreters may be considered to be slower to execute than a compiled program; however, the difference is negligible, and generally speed of execution isn't much of a concern when it comes to malware. Python is not a hard language to learn, and there are a lot of community-developed libraries. One challenge, though, is that you may need a Python interpreter, unless you go through the step of getting a Python compiler and compiling your script. Windows systems wouldn't commonly have a Python interpreter installed.
19. B. The expression host 192.168.10.5 is BPF indicating that `tcpdump` should only capture packets to and from 192.168.10.5. If you wanted

to only get it to or from, you would need to modify host with `src` or `dest`.

20. C. Certificates can be revoked, but that's not what Diffie-Hellman is used for. Key management is a much broader topic than what Diffie-Hellman is used for. Diffie-Hellman is used for key exchange. It is a process that allows parties to an encrypted conversation to mutually derive the same key starting with the same base value.
21. D. While you might be imitating someone, imitation is not a social engineering principle. Neither social proof nor scarcity is at play in this situation. However, if you are calling from the help desk, you may be considered to be in a position of authority.
22. D. SNMPv3 implemented username and password authentication. With version 1, you used a cleartext community string. SNMP doesn't use hashes, and while the word *public* is often used as a community string, a public string is not a way to authenticate with SNMPv1.
23. A. Interprocess communications across systems using a network is called remote method invocation. The process that programs have to communicate with to get a dynamic port allocation is the RMI registry. This is the program you query to identify services that are available on a system that has implemented RMI.
24. C. When an ARP response is sent without a corresponding ARP request, it's an unexpected or unnecessary message, so it is a gratuitous ARP.
25. D. There are three date and time stamps commonly used in file metadata. When the file is created, that moment is stored. When a file is accessed by a user, that moment is stored. When a file is modified, that moment is stored. Accessed is not the same as modified since accessing a file could be read-only. You could open a file, expecting to modify it but not ending up doing the modification. The access time still changes. While moves, adds, and changes may sometimes be referred to as MAC like modified, accessed, and created, those are not tasks associated with file times.
26. C. Local vulnerabilities are used against applications that are not listening on the network. This means they require you to be “local” to

the machine and not remote. In other words, you have to be logged in somehow. A local vulnerability would not be used to collect passwords since you don't need a vulnerability to do that. Similarly, you don't need to make use of a vulnerability to manipulate logs or to pivot. Most of those would require you to have elevated permissions, though. A local vulnerability may be exploited to get you those elevated permissions.

27. A. Integrity is part of the CIA triad but isn't the principle that ties a signed message back to the subject of the signing certificate. Nonverifiability is nonsense, and authority isn't relevant here. Instead, nonrepudiation means someone can't say they didn't send a message if it was signed with their key and that key was in their possession and password-protected.
28. D. Biometrics and badge access are forms of physical access control. Phone verification could possibly be used as a way of verifying identity, but it won't protect against tailgating. A man trap, however, will protect against tailgating because a man trap allows only one person in at a time.
29. B. Bluesnarfing is an attack that connects to a Bluetooth device to grab data from that device. Bluejacking can be used to send information to a Bluetooth device that is receiving from the attacker, such as a text message. Neither of these attacks installs keyloggers. The victim device sends information to the attacker in a bluesnarfing attack.
30. B. The Biba security model covers data integrity. While other models cover confidentiality, none of them covers availability.

OceanofPDF.com

Chapter 1
Ethical Hacking

THE FOLLOWING CEH EXAM TOPICS ARE COVERED IN THIS CHAPTER:

- ✓ **Professional code of conduct**
- ✓ **Appropriateness of hacking**
- ✓ **Five phases of ethical hacking**

Welcome to the exciting world of information security and, specifically, the important world of what is referred to as *ethical hacking* or *penetration testing*. You're here because you want to take the exam that will get you the Certified Ethical Hacker (CEH) certification. Perhaps you have done the training from EC-Council, the organization that manages the CEH certification, and you want a resource with a different perspective to help you as you prepare for the exam. Or you've decided to go the self-study route and you have enough experience to qualify for the exam. One way or another, you're here now, and this book will help improve your understanding of the material to prepare for the exam.

The exam covers a wide range of topics, often at a deeply technical level, so you really need to have a solid understanding of the material. This is especially true if you choose to go on to the practical exam (a lab-based hands-on exam) to earn the CEH Master certification. This chapter, however, will be your starting point, and there is nothing technical here. In it, you'll get a chance to understand the foundations of the entire exam. First, you'll learn just what ethical hacking is, as well as what it isn't. The important part of the term *ethical hacking* is the *ethical* part. When you take the exam, you will be expected to abide by a code. It's essential to understand that code so you can live by it throughout your entire career.

Finally, you'll learn what EC-Council is, as well as the format and other details of the exam that will be useful to you. While some of it may seem trivial, it can be helpful to get a broader context for why the exam was created and learn about the organization that runs it. Personally, I find it useful to understand what's underneath something rather than experience it at a superficial level. As a result, you'll get the macro explanation, and you can choose to use it or not, depending on whether you find it helpful. It won't be part of the exam, but it may help you understand what's behind the exam so you understand the overall intentions.

Overview of Ethics

Before we start talking about ethical hacking, I will cover the most important aspect of that, which is ethics. You'll notice it's not referred to as “hacking ethically.” It's ethical hacking. The important part is in the front. Ethics can be a challenging subject because you will find that they are not universal. Different people have different views of what is ethical and what is not ethical. It's essential, though, that you understand what ethics are and what is considered ethical and unethical from the perspective of the Certified Ethical Hacker certification. This is a critical part of the exam and the certification. After all, you are being entrusted with access to sensitive information and critical systems. To keep yourself viable as a professional, you need to behave and perform your work in an ethical manner. Not only will you be expected to behave ethically, you will be expected to adhere to a code of ethics.

As part of the code of ethics, you will be sworn to keep information you obtain as part of your work private, paying particular attention to protecting the information and intellectual property of employers and clients. When you are attacking systems that belong to other people, you could be provided with internal information that is sensitive. You could also come across some critical information vital to the organization for which you are working. Failing to protect any of that data violates the code of ethics by compromising the confidentiality of that information.

You are expected to disclose information that needs to be disclosed to the people who have engaged your services. This includes any issues that you have identified. You are also expected to disclose potential conflicts of

interest that you may have. It's important to be transparent in your dealings and also do the right thing when it comes to protecting your clients, employers, and their business interests. Additionally, if you come across something that could have an impact on a large number of people across the Internet, you are expected to disclose it in a responsible manner. This doesn't mean disclosing it in a public forum. It means working with your employer, any vendor that may be involved, and any computer emergency response team (CERT) that may have jurisdiction over your findings.

The first-time responsible disclosure was identified and documented in the 1990s. The security researcher Rain Forest Puppy developed a full disclosure policy, sometimes called the Rain Forest Puppy Policy (RFP or RFPolicy). It advocated working closely with vendors to ensure they had time to fix issues before announcing them. At the time, there was a tendency for so-called researchers to just publish findings to the public to make a name for themselves without regard to the possibility of exposing innocent people when the vulnerabilities they found were exploited by attackers.

On the other side, companies that developed software hadn't caught up with the idea that they needed to be on top of vulnerabilities, and the slow months- or years-long pace of software development wasn't possible any longer with word of vulnerabilities getting out within minutes around the world. Hackers may have tried to notify a company only to have that company ignore the contact. Other companies may have acknowledged the bug but then dragged their feet about getting fixes out to their customers. The RFPolicy was an attempt to ensure that those who found vulnerabilities didn't just announce them indiscriminately but also had the ability to make the announcement if the company started to drag their feet. Wide acceptance of this policy within the security community dramatically increased the collaboration between those who were looking for vulnerabilities and those companies who had to be conscious of their consumers who may be exposed to attack if vulnerabilities were announced.

For examples of responsible disclosure, look at the work of Dan Kaminsky. In the mid-2000s, he found serious flaws in the implementations of the Domain Name System (DNS), which impacts everyone on the Internet. He worked responsibly with vendors to ensure that they had time to fix their implementations and remediate the vulnerabilities before he disclosed them.

In the end, he did disclose the vulnerabilities in a very public manner, but only after vendors had time to fix the issue. This meant he wasn't putting people in the path of compromise and potential information disclosure. Even though he was using the software in a way that it wasn't intended to be used, he was using an ethical approach by attempting to address an issue before someone could make use of the issue in a malicious way.

As you perform work, you will be given access to resources provided by the client or company. Under the EC-Council code of ethics you will need to agree to, you cannot misuse any of the equipment. You can't damage anything you have access to as part of your employment or contract. There will be times when the testing you are performing may cause damage to a service provided by the infrastructure of the company you are working for or with. As long as this is unintentional or agreed to be acceptable by the company, this is okay. One way to alleviate this concern is to keep lines of communication open at all times. If it happens that an unexpected outage occurs, ensuring that the right people know so it can be remedied is essential.

Perhaps it goes without saying, but you are not allowed to engage in any illegal actions during a penetration testing campaign. Similarly, you cannot have been convicted of any felony. Along the same lines, though it's not directly illegal, you can't be involved with any group that may be considered “black hat,” meaning they are engaged in potentially illegal activities, such as attacking computer systems for malicious purposes.

Colorful Terminology

You may regularly hear the terms *white hat*, *black hat*, and *gray hat*. White-hat hackers are people who always do their work for good. Black-hat hackers, probably not surprisingly, are people who do bad things, generally actions that are against the law. Gray-hat hackers, though, fall in the middle: they are working for good, but they are using the techniques of black-hat hackers.

These terms are falling out of favor due to their association with race; several newer sets are becoming common, such as *authorized*, *unauthorized*, and *semi-authorized* entities. The original terms may still be in use by EC-Council, but it is important to be aware of the evolution of terminology.

Communication is also important when you embark on an engagement, regardless of whether you are working on contract or are a full-time employee. When you are taking on a new engagement, it's essential to be clear about the expectations for your services. If you have the scope of your services in writing, everything is clear and documented. As long as what you are being asked to do is not illegal and the scope of activities falls within systems run by the company you are working for, your work would be considered ethical. If you stray outside of the scope of systems, networks, and services, your actions would be considered unethical.

When you keep your interactions professional and ensure that it's completely clear to your employer what you are doing, as long as your actions are against systems belonging to your employer, you should be on safe ground ethically.

Overview of Ethical Hacking

These days, it's hard to look at any source of news without seeing something about data theft, Internet-based crime, or various other attacks against people and businesses. What we see in the news, actually, are the big issues, with large numbers of records compromised or big companies

breached. What you don't see is the number of system compromises where the target of the attack is someone's personal computer or other device. Consider, for example, the Mirai botnet, which infected smaller, special-purpose devices running an embedded implementation of Linux. The number of devices thought to have been compromised and made part of that botnet is well over 100,000, with the possibility of there being more than one million.

Each year, millions of new pieces of malware are created, often making use of new vulnerabilities that have been recently discovered. Since 2005, there has not been a year without at least 10 million data records compromised. In the year 2017, nearly 200 million records were compromised. These numbers are just from the United States. To put this into perspective, there are only about 250 million adults in the United States, so it's safe to say that every adult has had their information compromised numerous times. To be clear, the data records that we're talking about belong to individual people and not to businesses. There is minimal accounting of the total value of intellectual property that may have been stolen, but it's clear that the compromise has been ongoing for a long time.

All of this is to say, there is an urgent need to improve how information security is handled. It's believed that to protect against attacks, you have to be able to understand those attacks. Ideally, you need to replicate the attacks. If businesses are testing attacks against their own infrastructure early and often, those businesses could be in a better position to improve their defenses and keep the real attackers out.

This type of testing is what ethical hacking really is. It is all about ferreting out problems with the goal of improving the overall security posture of the target. This may be for a company in terms of their infrastructure or even desktop systems. It may also be performing testing against software to identify bugs that can be used to compromise the software and, subsequently, the system where the software is running. The aim is not to be malicious but to be on the “good” side to make the situation better. This is something you could be hired or contracted to perform for a business. They may have a set of systems or web applications they want tested. You could also have software that needs to be tested. There are a lot of people who perform testing on software—both commercial and open source.

Ethical hacking can be done under many different names. You may not always see the term *ethical hacking*, especially when you are looking at job titles. Instead, you will see the term *penetration testing*. It's essentially the same thing. The idea of a penetration test is to attempt to penetrate the defenses of an organization. That may also be the goal of an ethical hacker. You may also see the term *red teaming*, which is generally considered a specific type of penetration test where the testers are adversarial to the organization and network under test. A red teamer would actually act like an attacker, meaning they would try to be stealthy so as not to be detected.

One of the challenging aspects of this sort of activity is having to think like an attacker. Testing of this nature is often challenging and requires a different way of thinking. When doing any sort of testing, including ethical hacking, a methodology is important, as it helps ensure that your actions are both repeatable and verifiable. There are a number of methodologies you may come across. Professionals who have been doing this type of work for a while may have developed their own style. However, they will often follow common steps, such as the ones I am going to illustrate as we move through the chapter.

EC-Council helps to ensure that this work is done ethically by requiring anyone who has obtained the Certified Ethical Hacker certification to agree to a code of conduct. This code of conduct holds those who have their CEH certification to a set of standards ensuring that they behave ethically, in service to their employers. They are expected to not do harm and to work toward improving the security posture rather than doing damage to that posture.

Attack Modeling

As with so many things, using a methodology is valuable when it comes to ethical hacking or security testing. Methodologies can help with consistency, repeatability, and process improvement. Consistency is important because you want to run the same sets of tests or probes no matter who you are testing against. Let's say you are working with a company that keeps asking you back. Without consistency, you may miss some findings from one test to another, which may let the client think they improved, or the finding doesn't exist any longer. This would be a bad

impression to leave a company with. Similarly, repeatability gives you the ability to do the same tests every time you run the assessment. In fact, if you are working with a team, every one of you should be able to run the sets of tests. Again, you want to be sure that any organization you are assessing will have the same perspective on their security posture, no matter how many times they come to you and no matter who the organization is.

There are some testing or assessment methodologies that get used throughout the industry, including the Penetration Testing Execution Standard (PTES) and the Open Source Security Testing Methodology Manual (OSSTMM). These methodologies are typically built around expectations of what an attacker would do or how attackers operate. These may not map perfectly to how attackers operate in the real world, but they do help to ensure a consistency and breadth of approach to security testing, which makes them valuable. In addition, many common security testing methodologies are models of how attackers operate. The first is the cyber kill chain, another is the attack life cycle, while a third is the MITRE ATT&CK framework. When we get to look at the methodologies of ethical hacking, you will see the similarities in these models to the phases of ethical hacking used by EC-Council.

Cyber Kill Chain

A commonly referred–to framework in the information security space is the cyber kill chain. A kill chain is a military concept of the structure of an attack. The idea of a kill chain is that you can identify where the attacker is in their process so you can adapt your own response tactics. Lockheed Martin, a defense contractor, adapted the military concept of a kill chain to the information security (or cybersecurity) space. Figure 1.1 shows the cyber kill chain, as developed by Lockheed Martin.

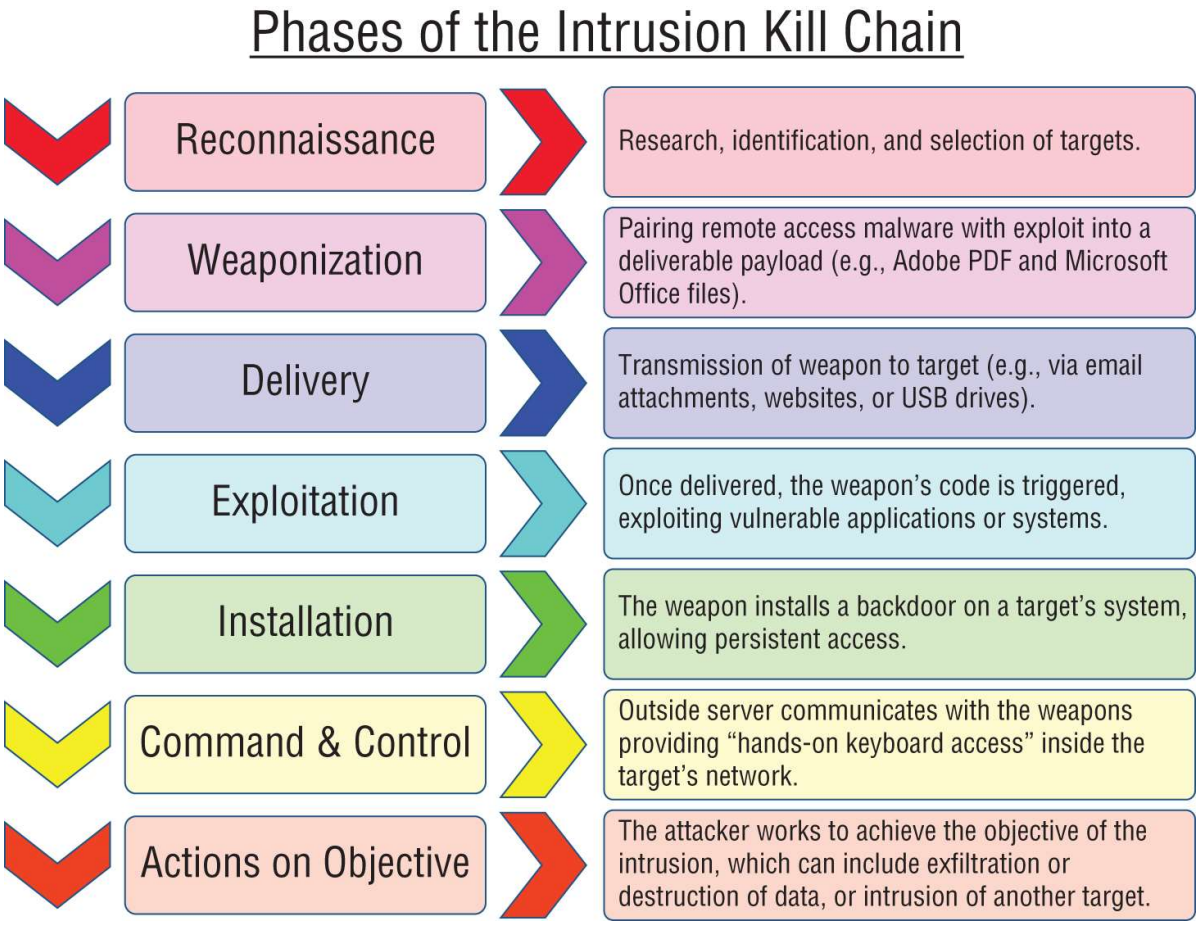


FIGURE 1.1 Cyber kill chain

The first stage of the cyber kill chain is *reconnaissance*. This is where the attacker identifies their target as well as potential points of attack. This may include identifying vulnerabilities that could be exploited. There may be a lot of information about the target gathered in this phase, which will be useful later in the attack process.

Once the attacker has identified a target, they need to determine how to attack the target. This is where *weaponization* comes in. The attacker may create a custom piece of malware, for instance, that is specific to the target. They may just use a piece of common off-the-shelf (COTS) malware, though this has the potential to be discovered by antivirus software installed in the victim's environment. The attacker may decide this doesn't matter resulting in the attacker sending out more malicious software to more individuals.

Delivery is how you get the weapon (the malware or the link to a rogue website) into the victim's environment. This could be a network-based attack, meaning there is an exposed service that may be vulnerable to exploit remotely. This could be sending an attachment via email, or it could be that the malicious software is hosted on a web server the victim is expected to visit and they get infected when they hit the website. *Exploitation* could be when the malicious software infects the victim's system.

Exploitation leads to *installation*. The attacker will install additional software to maintain access to the system and perhaps give themselves remote access to the system. Once installation is complete, the attacker moves to *command & control*. You will sometimes see this referred to as C2 or C&C. The command-&-control phase gives attackers remote access to the infected system. This may involve installation of additional software, or it may involve sending directives to the infected system. The attacker may be trying to get information from the infected system or have the system perform actions like participating in a large-scale denial-of-service attack.

These actions are called *actions on objectives*. Each attacker may have different objectives they are trying to achieve. Attackers who are criminally oriented are probably looking for ways to monetize the infected systems by stealing information that could be stolen or by selling off access to another organization. So-called nation-state actors may be looking to gain access to intellectual property. No matter what the organization is, they have objectives they are trying to achieve. They will keep going until they achieve those objectives, so there is a lot of activity that happens in this phase of the kill chain.

Attack Lifecycle

The security technology and consulting company Mandiant often refers to a different methodology called the *attack life cycle*. This is different from the cyber kill chain, though there are some similarities. Rather than a theoretical exercise or one with a military focus, the attack life cycle describes exactly how attackers have operated for as far back as there have been attacks against computing infrastructure. If you go back and look at how the Chaos Computer Club operated in the 1980s or Kevin Mitnick and his contemporaries operated in the late 1970s into the 1980s and beyond,

you can map their actions directly into the attack life cycle. Figure 1.2 shows how the attack life cycle looks.

One significant difference between the attack life cycle and the cyber kill chain is a recognition that often an attack is not one-and-done. There is a loop that happens in the middle. Attackers don't keep launching attacks from outside the network. Once they get into the environment, they use the compromised systems as launch points for additional compromises within the environment. Attackers will gain access to a system and use that system and anything discovered there, like credentials, to move off to another system in the network. Before we get there, though, an attacker identifies a victim and potential attack possibilities in the *initial recon* stage. The attacker is doing reconnaissance, including identifying names and titles using open source intelligence, meaning they use public sources like social network sites, to generate attacks. To gain access, they launch attacks—commonly, these would be phishing attacks. This is the *initial compromise* stage.

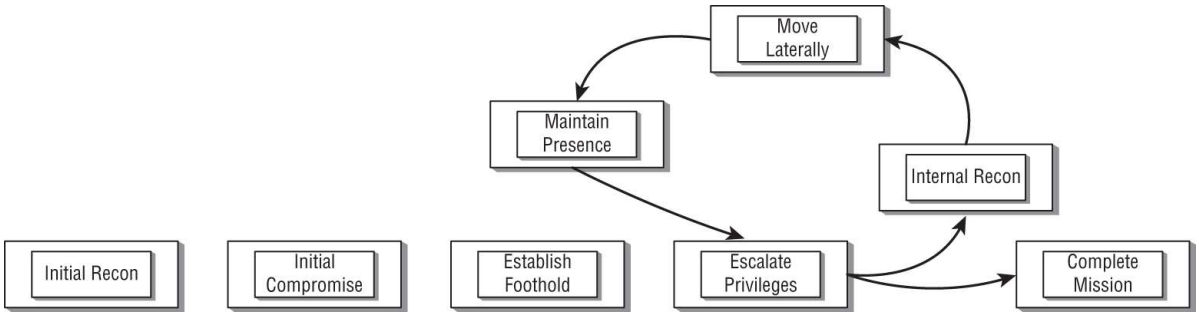


FIGURE 1.2 Attack life cycle

Once they have compromised a system, the attacker will work to *establish a foothold*. This includes making sure they retain access to the system so they can get back in when they need to. It's perhaps important to recognize that these attacks don't happen in a bang-bang fashion. It may take days or weeks to move from one phase of the attack life cycle to another. This depends on the organization performing the attacks. These are not individuals. They are organizations, so there may be different employees working on different stages.

To do much else, the attacker will need to *escalate privileges*. They need to have administrative privileges to move into the loop that happens as they continue to move through the environment, gathering additional systems

along the way. They will probably be gathering credentials from memory or disk here. They will also be investigating connections the system is known to have had with other systems in the network. This is a form of *internal reconnaissance*. They may also be trying to identify other credentials that are known to the system.

The reconnaissance is necessary to be able to *move laterally*. This is sometimes known as east-west movement. If you think about the network diagram, the connection to the outside world is quite often on the top. On a map, this would be north, so moving into and out of the network is known as north-south. Any movement within the organization is side to side or lateral movement. On a map, side to side would be east-west. To make those lateral movements, attackers need to know what systems there are. It may be servers, since individual systems are likely to know a lot of servers they communicate with, but it may also be individual workstations. In an enterprise network, it may be possible to authenticate using captured credentials against other workstations, which may have access to different sets of servers.

With every system the attacker gets access to, they need to *maintain presence*. This means some form of persistence, so any malware that is allowing the attacker access remains running. You might use the Windows registry, scheduled tasks, or other types of persistence to keep any malware running so the attacker can keep getting back in when they want.

The last phase of the attack life cycle, though leaving it until the end is misleading, is *complete mission*. Again, attacks tend not to be one-and-done. Once an attacker is in your environment, they will likely be continuing to revisit to see if there is anything else they need. They may be continuing to get a broader reach within the organization. The complete mission phase is where data may be exfiltrated from the environment. This, again, may not be a onetime thing. The attacker may continue to find additional targets in the environment to exploit, which would likely mean additional exfiltration. This means there would be continuous returns to this phase. After all, if you are planning to take up years-long residence, you don't want to wait years before getting data out because you can't, as an attacker, ever know when something may change and you lose access.

MITRE ATT&CK Framework

While the attack life cycle does a good job of describing the process an attacker goes through, it does not describe the specific behaviors used by the attacker, which are called techniques, tactics, and procedures (TTPs). The MITRE ATT&CK Framework is a taxonomy of TTPs, which means it is a way of organizing TTPs that have been seen in the real world into a set of categories. Mostly, the categories follow the same attack trajectory seen in the attack life cycle and the cyber kill chain, though there are some categories that are called out separately because it's useful to understand some of the specific TTP categories that may be done in a parallel stream or be part of multiple stages of the attack life cycle or cyber kill chain. Examples include resource development and execution. Following are the stages the ATT&CK Framework identifies.

Reconnaissance The attacker is looking for victims or ways to get into victims' systems that have been identified.

Resource Development Infrastructure for managing compromised hosts is put together here, as well as developing exploits or collecting credentials from other sources that could be used.

Initial Access Systems or user accounts are compromised to provide the attacker access to a resource that can be used.

Execution This is not a stage itself, but instead describes a series of actions or behaviors an attacker might use to maintain access to the system. This could include, for instance, executing PowerShell scripts.

Persistence The attacker needs to ensure they maintain access beyond reboots or other system changes, so they need to be sure they have a program that always runs when the system is started, or at least when a user logs in.

Privilege Escalation As user behavior is restricted, attackers would typically look to gain administrative privileges. The process of obtaining that level of permissions is called privilege escalation.

Defense Evasion Businesses will do a lot of work trying to protect systems, looking for malware and instances of persistence. When attackers try to get access and maintain access regardless of the protection measures in place, it's defense evasion and may include

masquerading or execution hijacking or tampering with protections in place.

Credential Access A common attack practice is to gather usernames and passwords. This may be done either from previous attacks or from systems or users directly. Any username and password set may be useful at some point.

Discovery Any activity that collects information within the victim environment could be considered discovery.

Lateral Movement Attackers will generally move from one system to another within the victim environment, to collect more information or to gather details about systems or users that could be used elsewhere.

Collection Once the attacker has found information they want to use or sell, they need to pull it together. This is the collection referred to here. It may be something simple like staging the data somewhere in the network.

Command and Control The attacker needs a way of getting remote access to systems or to send commands to those systems. Usually, there is infrastructure in place to perform this command and control work. With firewalls in place, direct access to victim systems is not commonly possible so the connection needs to be initiated from the inside of the network.

Exfiltration Data that has been collected needs to be moved out to the attacker locations so it can be dealt with. Moving the data out of the target environment to the attacker's place is exfiltration.

Impact Attackers aren't always looking to steal information. Sometimes, they are looking to be destructive, or in the case of some types of ransomware, they are looking to modify data by encrypting it so victims can't get access, requiring they pay the attacker. These are the types of activities that fall under impact.

The MITRE ATT&CK Framework continues to be updated with new TTPs as they are discovered. These TTPs are different from a collection of exploits, though. You will not find anything like step-by-step instructions

for performing an attack. Instead, you will find reasonably high-level and generic descriptions of activities like network sniffing or escape to host.

Methodology of Ethical Hacking

The basic methodology is meant to reproduce what real-life attackers would do. You will see similarities here to both the cyber kill chain and the attack life cycle. Companies can shore up their security postures using information that comes from each stage covered here. One thing to keep in mind when it comes to information security is that not everything is about protection or prevention. You need to be able to detect all of these attacker activities.

Reconnaissance and Footprinting

Reconnaissance is where you gather information about your target. You want to understand the scope of your endeavor up front, of course. This will help you narrow your actions so you aren't engaging in anything that could be unethical. You'll have some sense of who your target is, but you may not have all the details. Gathering the details of your target is one of the reasons for performing reconnaissance. Another reason is that while there is a lot of information that has to be public just because of the nature of the Internet and the need to do business there, you may find information leaked to the rest of the world that the organization you are working for would do better to lock down.

The objective of reconnaissance and footprinting is determining the size and scope of your test. *Footprinting* is just getting an idea of the “footprint” of the organization, meaning the size and appearance. This means trying to identify network blocks, hosts, locations, and people. The information gathered here will be used later as you progress through additional stages.

Keep in mind that while you are looking for details about your target, you will find not only network blocks, which may exist within enterprise networks, but also potentially single hosts, which may belong to systems that are hosted with a service provider. As these systems will run services that may provide entry points or just house sensitive data, it's necessary to keep track of everything you gather and not limit yourself to information available about network blocks that the company may have.

In the process of doing this work, you may also turn up personal information belonging to employees at your target. This will be useful when it comes to social engineering attacks. These sorts of attacks are commonplace. In fact, some estimates suggest that 80 to 90 percent of infiltrations are a result of these social engineering attacks. They are not the only means of accessing networks, but they are commonly the easiest way in.

Scanning and Enumeration

Once you have network blocks identified, you will want to identify systems that are accessible within those network blocks; this is the scanning and enumeration stage. More important, however, you will want to identify services running on any available host. Ultimately, these services will be used as entry points. The objective is to gain access, and that may be possible through exposed network services. This includes not only a list of all open ports, which will be useful information, but also the identity of the service and software running behind each open port.

This may also result in gathering information that different services provide. This includes the software providing the service, such as NGINX, Apache, or IIS for a web server. Additionally, there are services that may provide a lot of details about not only the software but the internals of the organization. This may be usernames, for instance. Some Simple Mail Transfer Protocol (SMTP) servers will give up valid usernames if they are queried correctly. Windows servers using the Server Message Block (SMB) protocol or the Common Internet File System (CIFS) protocol can be asked for information. You can get details like the directories being shared, usernames, and even some policy information. The objective of this phase is to gather as much information as you can to have starting points for when you move into the next phase. This phase can be time-consuming, especially as the size of the network and enterprise you are working with grows. The more details you can gather here, the easier the next stage will be for you.

Gaining Access

Gaining access is what many people consider to be the most important part of a penetration test, and for many, it's the most interesting. This is where

you can demonstrate that some services are potentially vulnerable. You do that by exploiting the service. There are no theoretical or false positives when you have compromised a system or stolen data and you can prove it. This highlights one of the important aspects of any ethical hacking: documentation. Just saying, “Hey, I did this” isn't going to be sufficient. You will need to demonstrate or prove in some way that you did manage to compromise the system.

Technical attacks, like those exploiting vulnerabilities in listening network services, are sometimes thought of as how systems get compromised, but the reality is that social engineering attacks are far more likely to be the way attackers gain access to systems. This is one of the reasons why enumeration is important—because you need targets for social engineering attacks. There are a number of ways to perform social engineering attacks, including using email to either infect a machine with malware or get the user to provide information that can be used in other ways. This may be the username and password, for instance.

Another mechanism for gathering information from users is to get them to visit a website. This may be a website that you, as the attacker, have loaded with malicious software that will infect their systems. Or, as before, you may be asking them for information. You've seen malware mentioned twice here. Understanding how malware works and where it can be used can be an important part of gaining access.

You will not always be asked to perform social engineering attacks. Companies may be handling security awareness, which commonly includes awareness of social engineering attacks, in other ways and not want or expect you to do phishing attacks or web-based attacks. Therefore, you shouldn't rely on using these techniques, in spite of the comparative ease of doing so, to get access to systems.

Maintaining Access

Once you are in, emulating common attack patterns means that you should maintain access. If you've managed to compromise a user's system, when the user shuts the system down, you will lose access. This may mean that you will need to recompromise the system. Since exploits are not always guaranteed to be effective, you may well not get in the next time you

attempt the compromise. Beyond that, you may have used a compromise that relied on a vulnerability that was fixed. Your next attempt may fail because the vulnerability is no longer there. You need to give yourself other means to get into the system so you can make sure you retain the ability to see what is happening on that system and potentially the enterprise network overall.

This is another stage where malware can be beneficial. You may need to install a rootkit, for example, that can provide you with a backdoor as well as the means to obscure your actions and existence on the system. You may need to install additional software on the system to maintain access. This may require copying the software onto your target system once you have done the initial compromise.

Therefore, this stage isn't as simple as perhaps it seems. There may be a number of factors that get in the way of ensuring that you maintain access. There are, though, a number of ways of maintaining access. Different operating systems allow for different techniques, but each operating system version or update can make different techniques harder. Ethical hacking is dependent on the circumstances, which is part of what makes it challenging. There are no single answers or straightforward approaches. One Windows 10 system may be easily compromised because there are patches that are available but missing. Another Windows 10 system may be difficult to get into because it is up-to-date, and it has been locked down with permissions and other settings.

Maintaining access is often called *persistence*. This is where any access mechanism is installed to persist on a system. No matter whether a user logs out or reboots a system, the attacker can continue to get in. This is commonly done by installing software that reaches out, or beacons, to systems on the Internet somewhere. The reason for this is because inbound access is often blocked by a firewall. Outbound access is often allowed from the inside of a network in a completely unrestricted manner.

Covering Tracks

Covering your tracks is where you hide or delete any evidence to which you managed to get access. Additionally, you should cover up your continued access. This can be accomplished with malware that ensures that your

actions aren't logged or perhaps the malware misreports system information, like network connections.

One thing to keep in mind when you are trying to cover your tracks is that sometimes your actions may also provide evidence of your work. One example is that wiping logs on a Windows system will leave a log entry indicating that the logs have been wiped. This may be an indication to anyone watching the logs that someone tried to erase evidence. It's not a guarantee that the log wipe was malicious, but it may be enough to prompt someone to investigate further. Because of this, covering tracks can be challenging. This may, though, be exactly what you've been asked to do—challenge and test the response capabilities of the operations team. As a result, it's always important to keep in mind the objectives of your engagement.

Summary

It's hard to overstate the importance of ethics. You will be expected to adhere to a code of ethics when you sign up for your CEH certification and pass your exam. You'll need to act in a professional manner at all times with your clients and employers. You will need to be a responsible custodian of any data entrusted to you.

OceanofPDF.com